

EVALUACIÓN DE SEGURIDAD OFENSIVA

My File Server I

30 sep. 2026

CONTEXTO DEL ENGAGEMENT



Se evaluó la exposición real del servidor de archivos corporativo "My File Server I" ante un atacante con acceso a la red interna, mediante una prueba de penetración controlada en un entorno de laboratorio aislado.

METODOLOGÍA APLICADA

Evaluación alineada a PTES y OWASP Testing Guide, estructurada en fases: reconocimiento, enumeración de servicios, explotación inicial, escalada de privilegios, post-explotación y documentación de hallazgos bajo el modelo de riesgo CIA (Confidencialidad, Integridad, Disponibilidad).

NIVEL GENERAL DE RIESGO

Riesgo Global:
CRÍTICO

Tiempo de compromiso total del
sistema: menos de 1 hora

HALLAZGOS CRÍTICOS



Credenciales del sistema expuestas en texto plano y accesibles públicamente vía HTTP.



Recurso de almacenamiento compartido (SMB) con escritura anónima habilitada.



Kernel del servidor desactualizado, vulnerable a escalamiento de privilegios.

ESCENARIO DE IMPACTO EMPRESARIAL

Al alcanzarse privilegios de root, los pilares de seguridad de la información se ven comprometidos en su totalidad, con exposición directa de datos corporativos y riesgo de pivote hacia otros sistemas internos.

Confidencialidad: CRÍTICA	Integridad: CRÍTICA	Disponibilidad: ALTA
Continuidad del negocio: ALTA	Reputación corporativa: MEDIA	Cumplimiento normativo: MEDIA

MATRIZ DE RIESGO

CRÍTICA: credenciales en texto plano • escritura anónima en SMB • kernel sin parchar

ALTA: FTP anónimo • inyección de acceso SSH persistente

MEDIA: firma de mensajes SMB deshabilitada

RECOMENDACIONES ESTRATÉGICAS



Reconstrucción
inmediata

Reconstruir el servidor
desde imagen limpia



Rotación de
credenciales

Rotar credenciales y
eliminar accesos inyectados



Gestión de parches

Actualizar kernel y
establecer proceso formal

ROADMAP DE REMEDIACIÓN

Inmediato (0-7 días): reconstrucción del servidor, rotación de credenciales y cierre de accesos anónimos.

Corto plazo (2-4 semanas): actualización de kernel y hardening de servicios expuestos.

Mediano plazo (1-3 meses): monitoreo de integridad de archivos y segmentación de red.

Continuo: programa recurrente de pentesting y gestión de vulnerabilidades.

CONCLUSIÓN

El compromiso total del servidor se logró en menos de una hora, sin técnicas sofisticadas. El riesgo proviene de prácticas básicas de configuración, no de amenazas avanzadas.

La remediación inmediata es esencial para proteger la continuidad del negocio.

Se recomienda aprobar el roadmap de remediación propuesto.

GRACIAS